Investigando ataques relacionados a autenticação multifator

Antes de praticar, coloco aqui algumas informações importantes sobre A autenticação multifator:

A autenticação multifator (MFA) é o controle mais impactante contra ataques baseados em senhas. Uma vez que um invasor possui credenciais válidas, ela representa a barreira entre ele e a tomada completa da conta. A Microsoft relata que a MFA bloqueia mais de 99% dos ataques automatizados baseados em credenciais.

Como funciona no Entra ID

Quando um usuário faz login, o Entra ID divide a autenticação em dois desafios sequenciais:

Algo que você sabe: o usuário insere seu nome de usuário e senha. O Entra ID valida essas credenciais em relação ao diretório.

Algo que você possui: se a senha estiver correta (e uma política de Acesso Condicional que a imponha estiver ativa), o Entra ID envia um segundo desafio para um método pré-registrado.

Somente após ambos os fatores serem satisfeitos, o Entra ID gera um token de sessão e concede acesso ao recurso solicitado. Infelizmente, a MFA não é infalível. Os invasores desenvolveram técnicas para contorná-la sem nunca quebrar a criptografia. Esta tarefa aborda as técnicas mais relevantes que um analista deve reconhecer.

Fadiga (Bombardeio de Solicitações)

O invasor já possui credenciais válidas. Eles iniciam tentativas repetidas de autenticação em rápida sucessão, cada uma gerando uma notificação push do Authenticator no telefone da vítima. O objetivo é sobrecarregar o usuário até que ele aprove uma das tentativas, por frustração, confusão ou por acreditar erroneamente que se trata de uma solicitação legítima.

Este é um ataque, não um ataque técnico. Ele funciona porque as notificações push oferecem ao usuário um único botão para aprovar, sem qualquer contexto adicional sobre a origem da solicitação de login.

Como isso se manifesta nos registros:

Um grande volume de solicitações contra uma única conta em um curto período.

Códigos de erro relacionados, como 50074, 50076, 500121, repetidos.

Se o usuário aprovar, o código de erro 0 é exibido em seguida.

A Microsoft mitigou parcialmente esse problema com a correspondência de números (o usuário deve inserir um número exibido na tela de login em seu aplicativo Authenticator) e

contexto adicional (o aplicativo exibe a localização e o nome do aplicativo). Esses controles dificultam significativamente os ataques de fadiga.

Listar falhas de MFA por usuário

```
index="task-4" sourcetype="azure:aad:signin" (status.errorCode=50074 OR
status.errorCode=50076 OR status.errorCode=500121)
| stats count as mfa_failures values(status.errorCode) as errorCodes
values(status.failureReason) as failureReasons by userPrincipalName, ipAddress
| sort - mfa_failures
```

Troca de SIM

Quando o SMS é usado como método, um atacante pode convencer uma operadora de celular a transferir o número de telefone da vítima para um SIM que ela controla, permitindo que receba todos os códigos por SMS. Isso representa uma ameaça principalmente para contas de consumidores e organizações que ainda dependem de SMS. A mitigação é simples: abandonar o SMS como método de autenticação.

Nos registros de eventos, essa técnica é caracterizada por:

Um login bem-sucedido usando um dispositivo ou navegador incomum para o usuário.

Um login bem-sucedido de um local incomum para o usuário.

Phishing Adversary-in-the-Middle (AiTM)

O AiTM é uma técnica mais sofisticada. O atacante configura um proxy reverso entre a vítima e a página de login legítima da Microsoft. A vítima se autentica normalmente, incluindo o preenchimento do formulário, mas o proxy captura o token de sessão emitido após a autenticação. O atacante então reproduz esse token em sua própria máquina, ignorando completamente a autenticação da vítima, pois ela já ocorreu.

Do ponto de vista do token, a sessão é legítima. O ataque não a interrompe; ele rouba o resultado. O padrão pode ser descrito como:

O login é bem-sucedido sem uma nova solicitação porque o token já contém a prova de que a autenticação foi concluída durante a autenticação original (da vítima).

O IP e a localização de origem diferem daqueles onde a autenticação foi concluída originalmente.

O Acesso Condicional mostra a sessão como em conformidade. A política foi atendida, mas não pela pessoa que está usando o token agora.

É por isso que o roubo de token é tão perigoso: da perspectiva do Entra ID, tudo parece normal. As únicas anomalias são a geografia e o IP, que exigem que um analista conecte os pontos entre dois eventos de login separados.

Impossible Travel

Você pode ter notado que um invasor que burlou a autenticação, seja por meio de troca de SIM ou roubando um token de sessão (Ai™), geralmente acaba se autenticando de um local que não faz sentido físico em relação ao último local de login conhecido do usuário. Essa é a base de um dos sinais de detecção mais confiáveis do Entra ID: I**mpossible travel** (viagens impossíveis).

Por exemplo: um usuário faz login em São Paulo às 9h e, em seguida, a mesma conta faz login em Moscou às 9h45. Isso é fisicamente impossível. É improvável que um desses logins tenha sido realizado pelo usuário legítimo.

A Proteção de Identidade tenta detectar isso automaticamente e sinaliza como um evento de risco de Impossible travel. Mas, como mencionado anteriormente, você não pode confiar cegamente nesses alertas, pois às vezes eles não são precisos. Você pode procurar esse padrão proativamente, diretamente nos logs de login, usando a consulta Splunk abaixo e tentando identificar logins de diferentes países em um intervalo de tempo que seja fisicamente impossível:

Liste as atividades de login bem-sucedidas de um usuário:

```
index="task-4" sourcetype="azure:aad:signin" status.errorCode=0
| table _time, userPrincipalName, ipAddress, location.countryOrRegion,
conditionalAccessStatus
| sort - _time
```

Liste os alertas "impossibleTravel" nos registros de proteção de identidade:

```
index="task-4" sourcetype="azure:aad:identity_protection:riskdetection"
| where riskEventType="impossibleTravel"
| table _time, userPrincipalName, activity, ipAddress, location.countryOrRegion, riskLevel,
riskEventType
| sort - _time
```

Falsos Positivos Legítimos

Nem todo evento de impossible travel é malicioso. Antes de confirmar um incidente, considere os seguintes pontos:

VPNs corporativas — Um usuário que se conecta por meio de um nó de saída de VPN em outro país parecerá estar fazendo login a partir desse país, mesmo estando em seu escritório.

Túnel dividido — Parte do tráfego passa pela VPN, parte não, produzindo logins de vários locais aparentes simultaneamente.

IPs de serviços em nuvem — Logins automatizados de serviços da Microsoft ou integrações de terceiros podem produzir anomalias de localização.

Prática: Descobrir ataques em falhas de MFA

Descobertas usando as pesquisas no Splunk:

1 - Qual usuário foi alvo de um ataque de fadiga de MFA:

Descobri usando essa pesquisa para listas falhas de autenticação MFA:

```
index="task-4" sourcetype="azure:aad:signin" (status.errorCode=50074 OR
status.errorCode=50076 OR status.errorCode=500121)
| stats count as mfa_failures values(status.errorCode) as errorCodes
values(status.failureReason) as failureReasons by userPrincipalName, ipAddress
| sort - mfa_failures
```

userPrincipalName	ipAddress	mfa_failures	errorCodes	failureReasons
igor.bicalho@finegalo.thm	149.102.234.27	10	500121	Authentication failed during strong authentication request.

O usuário alvo foi: igor.bicalho@finegalo.thm

2 - Código de erro das solicitações de MFA que falharam

errorCodes
500121

Através dessa mesma pesquisa descobri o código de erro: 500121

3 - Código do país que o usuário normalmente usa para fazer login antes do ataque

Fazendo uma pesquisa por logins bem sucedidos percebi que o usuário que logins de países diferentes, com diferença de uma hora confirmando assim uma impossible travel.

Pesquisa:

index="task-4" sourcetype="azure:aad:signin" status.errorCode=0
| table _time, userPrincipalName, ipAddress, location.countryOrRegion, conditionalAccessStatus
| sort - _time

Antes do ataque os logins eram feitos da Dinamarca (DK) depois foi feito do Brasil (BR)

_time	userPrincipalName	ipAddress	locat
2026-03-04 13:26:22	igor.bicalho@finegalo.thm	149.102.234.27	BR
2026-03-04 12:20:22	igor.bicalho@finegalo.thm	96.0.24.134	DK
2026-03-04 09:05:17	igor.bicalho@finegalo.thm	96.0.24.134	DK
2026-03-03 14:37:22	igor.bicalho@finegalo.thm	96.0.24.134	DK
2026-03-03 09:13:29	igor.bicalho@finegalo.thm	96.0.24.134	DK
2026-03-02 11:15:19	igor.bicalho@finegalo.thm	96.0.24.134	DK
2026-03-02 10:12:58	igor.bicalho@finegalo.thm	96.0.24.134	DK

4- Quando o invasor conseguiu autenticar-se na conta do usuário

_time
2026-03-04 13:26:22

Aproveitando a mesma pesquisa anterior percebi que o invasor conseguiu autenticar-se nessa data e horário: 2026-03-04 13:26:22

Conclusão

A autenticação multifator (MFA) é fundamental contra ataques baseados em senhas garantindo uma camada extra de proteção em casos de senhas vazadas.
Em casos de falhas de configuração a pesquisa no Splunk se torna fundamental para a detecção e reação à incidentes.

Autor: Paulo Cesar
Formado em Segurança da informação
linkedin.com/in/paulo-cesar-security